Future Interns

Phishing Email

ANALYSIS & AWARENESS REPORT

Phishing Email Analysis Report

19-03-2026

Prepared By
Akhilesh Singh Choudhary

Intern

akhileshbadyal@gmail.com

Table of Contents

Table of Contents 2
1. Executive Summary 3
2. Introduction 4
3. Disclaimer 5
A. In-Scope Components 5
B. Out-of-Scope Components 5
4. Phishing Indicators Framework 6
5. Email Samples Overview 7
6. Email Analysis 8
7. Risk Classification Summary 21
8. Prevention & Awareness Guidelines 22
9. Do's and Don'ts for Employees 23

1. Executive Summary

In March 2026, as an intern under Future Interns, I conducted a phishing email analysis exercise using a curated set of 10 email samples, including real phishing emails received on email accounts. The objective was to identify phishing indicators, classify each email's risk, explain how the attack works, and produce actionable awareness guidelines.

During the analysis, all 10 email samples were examined and were classified as Phishing. Zero samples were classified as Safe. The samples represent:

- Fake job opportunity lures exploiting recognisable brand names (Deloitte, Genpact) — E-01
- Payment failure / storage-full scams impersonating cloud services — E-02
- Prize and giveaway lures (CVS Medicare kit) using Azure Blob for evasion — E-03
- Fake Microsoft security alert with credential-harvesting mailto: links — E-04
- Cryptocurrency investment fraud impersonating CoinDesk/Ripple — E-05
- Gambling spam with SPF FAIL, DKIM NONE, DMARC FAIL — E-06
- Fake IRS statement with redirect to South African co.za domain — E-07
- Fake DeWalt prize drill lure with DKIM FAIL and suspicious t.co redirect — E-08
- Fake Nonstick Cookware sweepstakes with SPF/DKIM/DMARC all NONE — E-09
- Jeff Bezos impersonation advance-fee fraud ($2.5M lottery) — E-10

Each analysis is supported by a screenshot from the Google Admin Toolbox Message Header Analyser confirming SPF, DKIM, and DMARC authentication results. Real email samples (E-01, E-02, E-03) are additionally verified using Cisco Talos Intelligence IP reputation lookups.

2. Introduction

Phishing is one of the most prevalent cyber threats facing organisations today. Attackers craft deceptive emails that impersonate trusted brands, financial institutions, or colleagues to trick recipients into revealing credentials, transferring funds, or installing malware. The email samples analysed in this report were all received by real inboxes and represent the type of threat any employee might encounter.

This analysis applied a passive, read-only methodology: email headers were examined using the Google Admin Toolbox Message Header Analyser, sender domains and authentication results (SPF, DKIM, DMARC) were evaluated from both the raw headers and the tool screenshots, and body content and embedded links were analysed without being activated.

Additionally, the real-world samples (E-01, E-02, E-03) were verified using Cisco Talos Intelligence WHOIS lookups and header analysis

3. Disclaimer

This report does not constitute and should not be construed as a guarantee of freedom from phishing attacks. This report was produced as part of the Future Interns Cyber Security Task 02 (2026) for educational purposes only. All email samples were analysed in a read-only, passive manner. No phishing infrastructure was interacted with, no links were clicked, and no credentials were entered at any point during this analysis.

The email samples from public GitHub repositories are used strictly for educational study. Real email samples (E-01, E-02, E-03) were received on personal email accounts with the consent of the account holder. The Cisco Talos Intelligence lookups are based on publicly available IP reputation data at the time of analysis and may have changed since this report was written.

A. In-Scope Components

- 10 email samples: Deloitte job offer, Payment skipping, Picked up, sample-10, sample-1003, sample-14, sample-7007, sample-104, sample-106, sample-107
- Email header analysis via Google Admin Toolbox — SPF, DKIM, DMARC results (with screenshots)
- Cisco Talos Intelligence IP reputation lookups for real received email samples
- Sender domain analysis — legitimacy, lookalike domains, display name spoofing
- Body content — urgency language, personalisation, social engineering tactics
- Embedded hyperlinks — displayed text vs actual destination domain

B. Out-of-Scope Components

- Clicking or following any hyperlinks embedded in the emails
- Downloading or executing any referenced attachments
- Interacting with any live infrastructure or websites
- Attribution or law-enforcement reporting

4. Phishing Indicators Framework

Each email was assessed against four core phishing red-flag categories. Two or more confirmed indicators = Phishing; one indicator = Suspicious; zero = Safe.

Indicator	Description
1. Fake/Suspicious Sender Domain	From address domain does not match claimed organisation
2. Urgency & Fear-Based Language	Artificial time pressure or threats designed to bypass rational thinking
3. Suspicious Link URL	Destination URL does not match claimed sender or uses untrusted domain
4. Generic/Inappropriate Greeting	Email does not address recipient by real name

Classification	Criteria
Phishing	2 or more indicators found
Suspicious	1 indicator found
Safe	No indicator found

5. Email Samples Overview

ID	Subject / Filename	Sender Domain	SPF	DKIM	DMARC
E-01	Congratulations! Selected for DELOITTE	freshersindia.in	PASS	PASS	PASS
E-02	Payment skipping	gmail.com (masquerading)	PASS	PASS	PASS
E-03	Picked up — CVS Medicare Kit	gmail.com / cortezpark.org	PASS	PASS	PASS
E-04	Microsoft account unusual signin activity	access-accsecurity.com	NONE	NONE	PERMERROR
E-05	More benefits from Ripple / XRP Allocation	mg.areafellowship.com	PASS	PASS	bestguesspass
E-06	Massive 400% Welcome Offer + 50 free spins	and.co.uk	FAIL	NONE	FAIL
E-07	Time to Review Your Statement: ID-23221693	globalnet.co.uk	PASS	PASS	bestguesspass
E-08	Re: Your chance to receive FREE Dewalt Drill	hotprodhau.com	NONE	FAIL	NONE
E-09	Re: Shipment Pending - Nonstick Cookware	electroplan.com	NONE	NONE	NONE
E-10	YOUR $2,500,000.00 (Jeff Bezos impersonation)	gmail.com (masquerading)	PASS	PASS	PASS

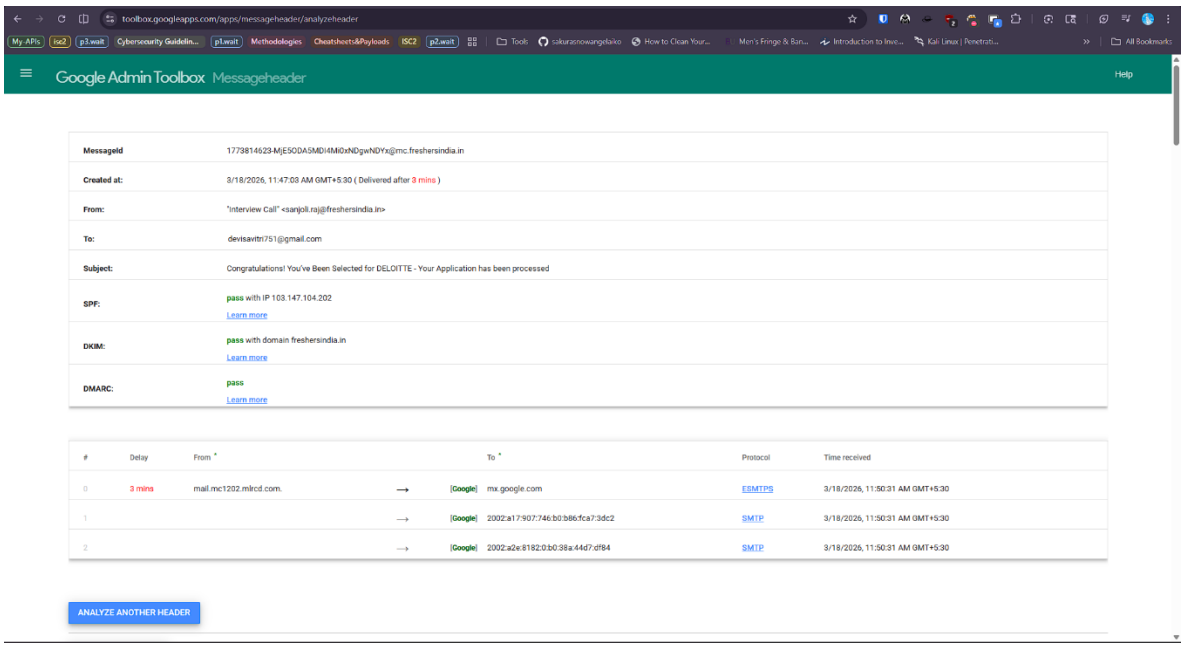
Classification	Count
Phishing	10
Suspicious	0
Safe	**0**
Total	**10**

6. Email Analysis

Each entry includes the analysis table followed by the actual Google Admin Toolbox Message Header Analyser screenshot confirming SPF, DKIM, and DMARC results. For real emails (E-01, E-02, E-03), Cisco Talos Intelligence IP reputation screenshots are also included.

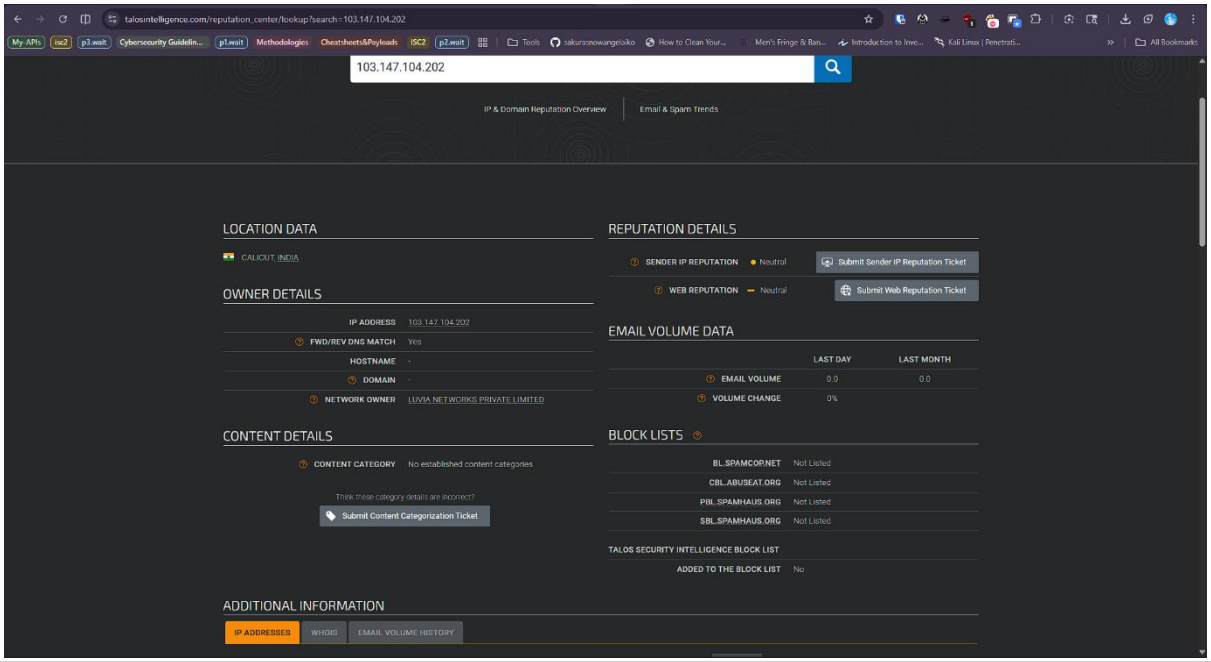
E-01 Deloitte Job Offer — freshersindia.in Lure	
Description	Subject: 'Congratulations! You've Been Selected for DELOITTE — Your Application has been processed'. Sent by sanjoli.raj@freshersindia.in — a bulk email marketing platform with zero affiliation to Deloitte LLP. The body addresses 'Ankush Bhadwar' by name (harvested from a job-site database) and mentions a salary of up to Rs.16.7 LPA. The actual company promoted in the body is Genpact, not Deloitte — a deliberate bait-and-switch. All links route through mc.freshersindia.in tracking URLs. Delivered after a 3-minute delay indicating bulk-mail queuing.
Sender / Target	From: 'Interview Call' <sanjoli.raj@freshersindia.in> | Sending IP: 103.147.104.202 | To: devi*******751@gmail.com
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake domain — freshersindia.in is not deloitte.com | CONFIRMED: FOMO urgency — 'Don't miss out on this golden opportunity' | CONFIRMED: Suspicious links — all hrefs via mc.freshersindia.in tracking redirects | CONFIRMED: Misleading subject — subject says DELOITTE, body promotes Genpact (bait-and-switch)
How Attack Works	A job seeker excited by the Deloitte subject line clicks 'Schedule Your Interview Here'. The tracking link redirects to a fake interview booking form harvesting personal details (phone, address, NID) or a registration fee payment page.
Countermeasures	Always verify job offers at the company's official careers page (careers.deloitte.com). If the subject says DELOITTE but the body promotes another company, it is a scam. Never pay any fees to attend a job interview.

Screenshot — Google Admin Toolbox Header Analysis (E-01):



E-01

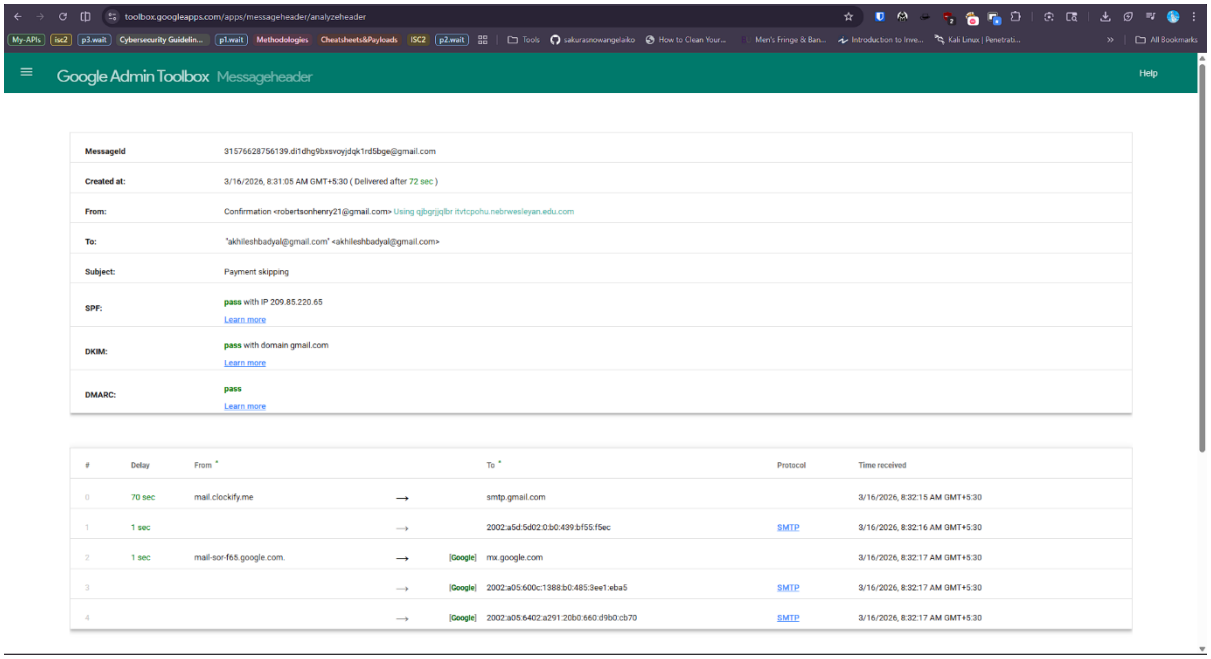
Screenshot — Cisco Talos Intelligence IP Reputation (E-01)



E-01 Talos

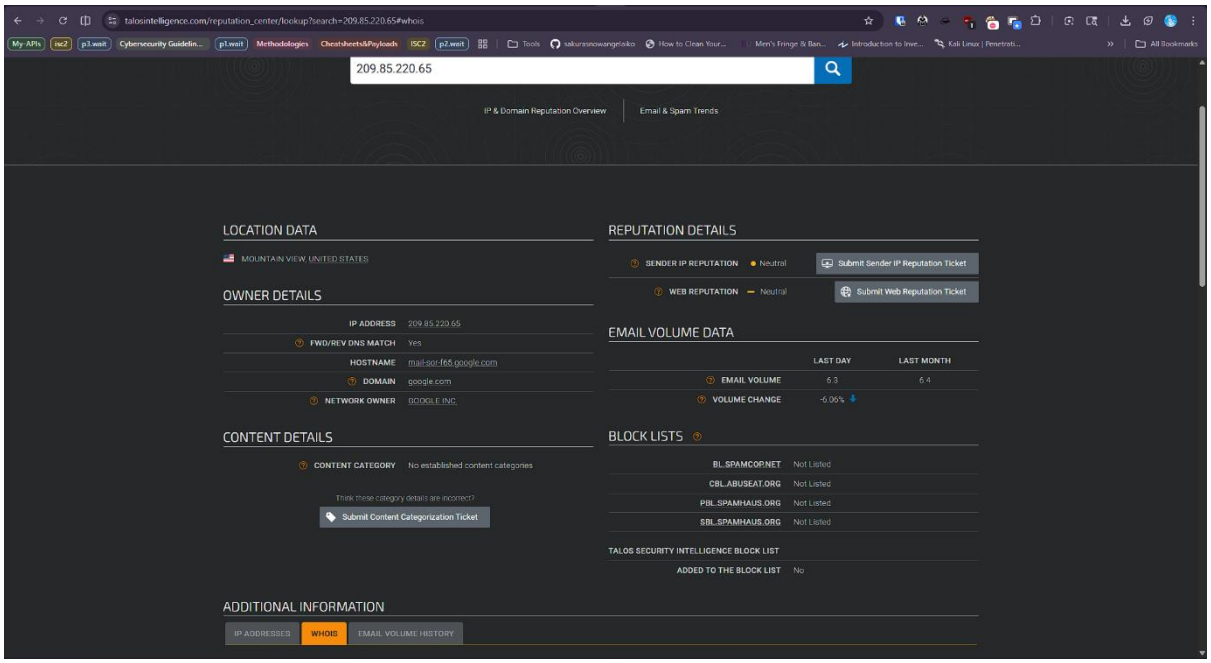
E-02 Payment Skipping — Fake Cloud Storage Payment Failure	
Description	Subject: 'Payment skipping'. From: Confirmation <robertsonhenry21@gmail.com>. The X-Google-Original-From header reveals the true relay origin as a nebrwesleyan.edu server. The HTML body impersonates a cloud storage service showing a '250 GB 100% Full — Payment Declined' warning. Both 'Update Payment' and 'Manage Plan' buttons link to nvbiydhhsyojshgsthdhjs.blob.core.windows.net — a random Azure Blob Storage subdomain. A hidden educational PDF slide deck is embedded as decoy content to evade spam filters. Delivered after 72 seconds.
Sender / Target	From: Confirmation <robertsonhenry21@gmail.com> | Relay: mail.clockify.me (185.53.211.249) | True origin relay: nebrwesleyan.edu | All links: nvbiydhhsyojshgsthdhjs.blob.core.windows.net
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake sender — personal Gmail claiming to be a cloud storage service | CONFIRMED: Fear/urgency — 'Files in Sync Pending may be lost if payment not resolved' | CONFIRMED: Suspicious links — random Azure Blob URL, not any legitimate cloud storage billing page | CONFIRMED: No personal greeting — 'Storage management for your connected account'
How Attack Works	Alarmed by the 100% Full / Payment Declined warning, the victim clicks 'Update Payment' and lands on an Azure-hosted page requesting payment card details (number, expiry, CVV). The embedded PDF webinar content is a known spam-filter evasion technique.
Countermeasures	Cloud storage providers (Google, Microsoft, Dropbox) never email from personal Gmail accounts. A legitimate billing page is never hosted on a random Azure Blob subdomain. Always update payment details by navigating directly to the service website.

Screenshot — Google Admin Toolbox Header Analysis (E-02):



E-02

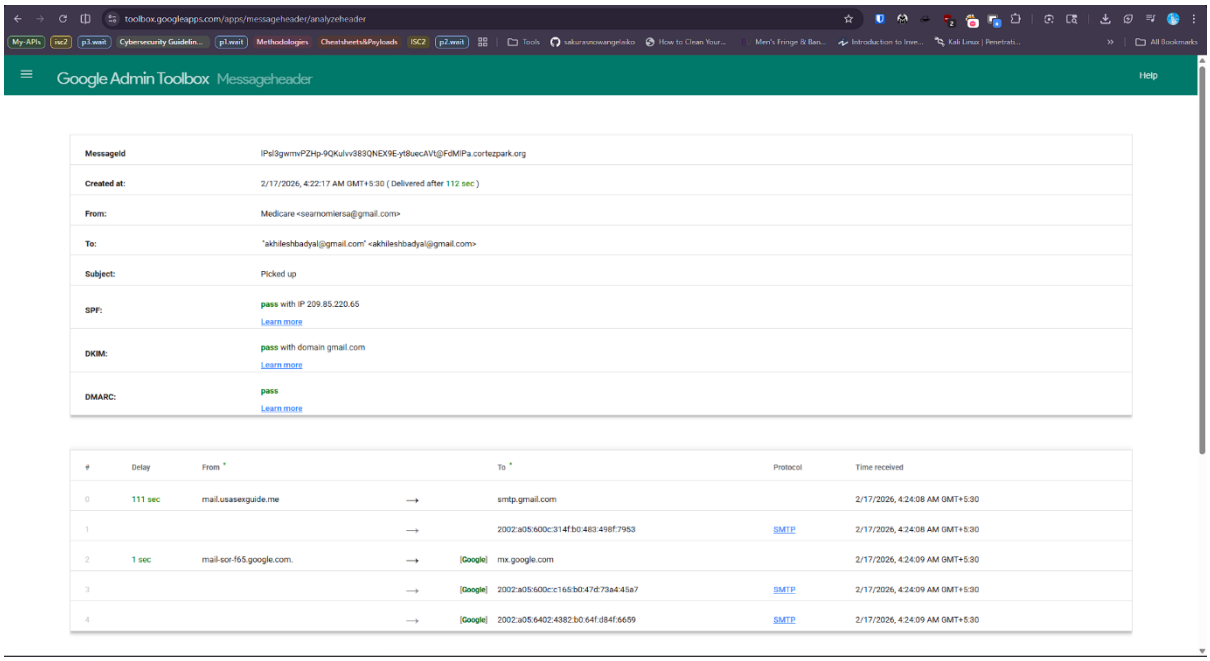
Screenshot — Cisco Talos Intelligence IP Reputation (E-02):



E-02 Talos

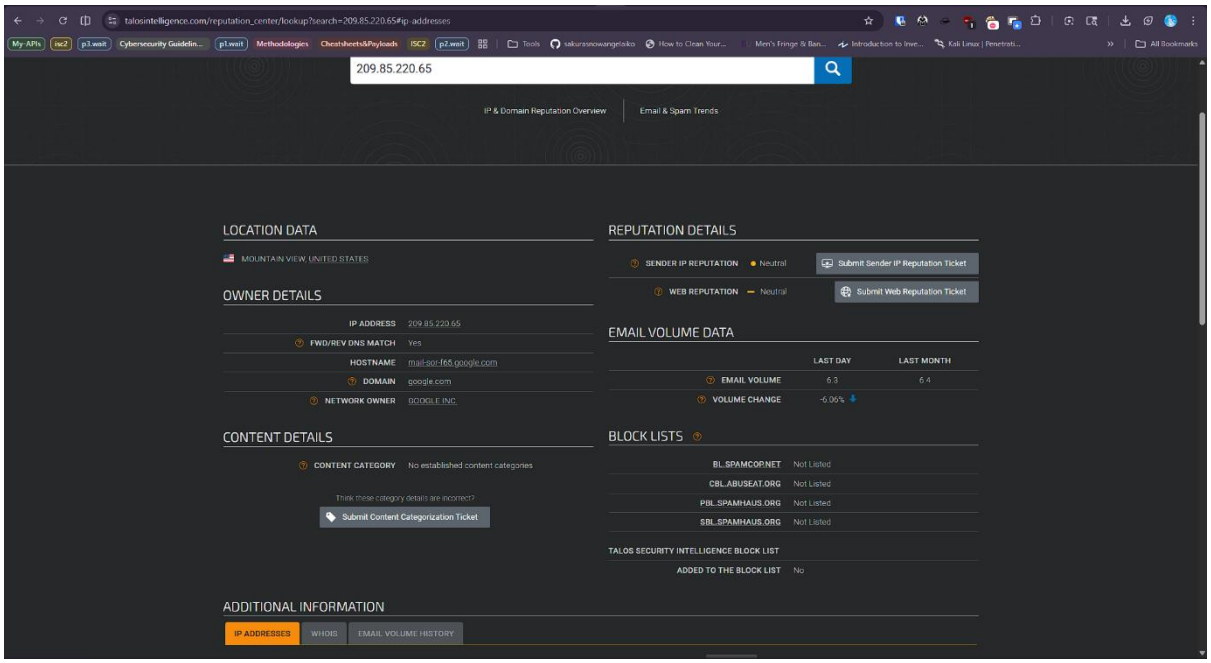
E-03 Picked Up — CVS Medicare Kit Scam	
Description	Subject: 'Picked up'. From: Medicare <searnomiersa@gmail.com>. X-Google-Original-From reveals true origin: info@cortezpark.org. The HTML body contains two parts: a hidden multilingual school newsletter (spam-filter evasion decoy) and a polished CVS Pharmacy-branded prize notification. The entire visible email is wrapped in a single hyperlink pointing to esrztzrzyrgdjfdrtzrtzed.blob.core.windows.net (a random Azure Blob URL). The recipient is greeted as 'Hi akhileshbadyal' (email address used as name). Delivered after 112 seconds.
Sender / Target	From: Medicare <searnomiersa@gmail.com> | X-Google-Original-From: info@cortezpark.org | Relay: mail.usasexguide.me (81.28.4.13) | All links: esrztzrzyrgdjfdrtzrtzed.blob.core.windows.net
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake sender — 'Medicare' via personal Gmail; CVS branding with no @cvs.com domain | CONFIRMED: Prize urgency — 'You have been selected as one of our valued winners — Claim Your Prize Now!' | CONFIRMED: Suspicious links — entire email is one giant link to a random Azure Blob URL | CONFIRMED: Generic greeting — 'Hi akhileshbadyal' (email address, not a real name)
How Attack Works	Any click anywhere in the email lands on an Azure-hosted CVS survey page requesting personal details and a 'shipping fee', harvesting card data. The relay server (mail.usasexguide.me) is clearly unrelated to any healthcare provider.
Countermeasures	CVS Pharmacy and Medicare do not send free kit notifications via Gmail accounts. When an entire email is a single clickable link, treat it as a major red flag. Legitimate companies never ask for a 'shipping fee' to receive a free prize.

Screenshot — Google Admin Toolbox Header Analysis (E-03):



E-03

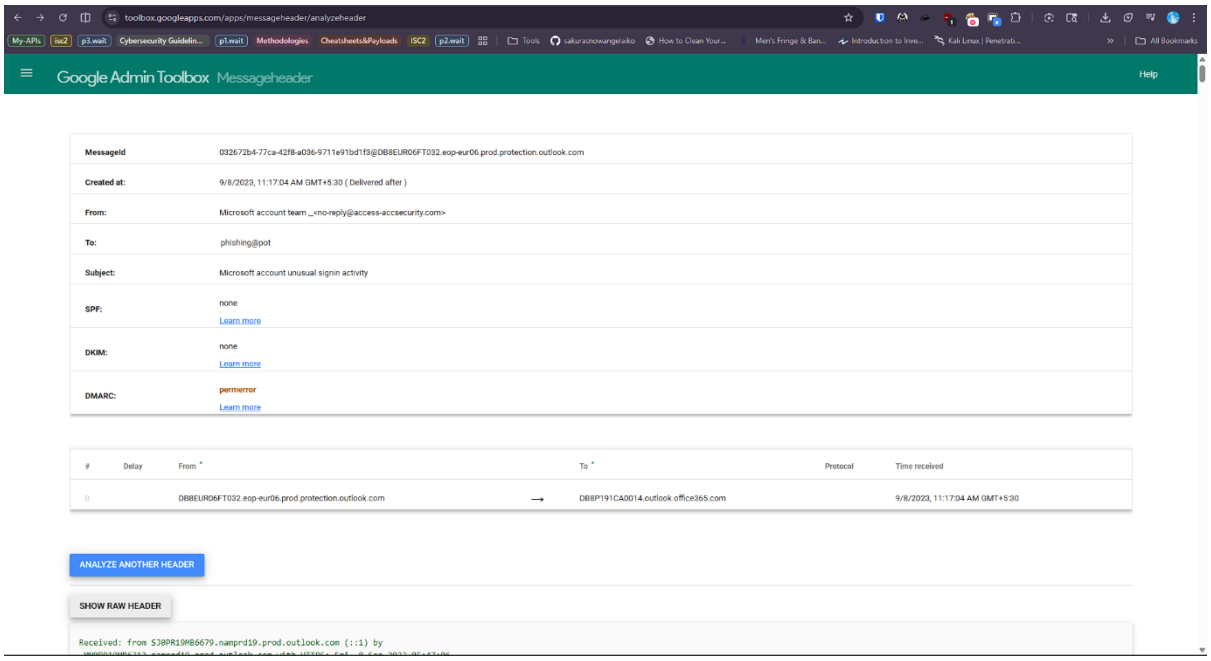
Screenshot — Cisco Talos Intelligence IP Reputation (E-03):



E-03 Talos

E-04 sample-10 — Fake Microsoft Unusual Sign-In Alert	
Description	Subject: 'Microsoft account unusual signin activity'. From: 'Microsoft account team' <no-reply@access-accsecurity.com>. This domain has no affiliation with Microsoft (legitimate alerts come from @microsoft.com). Return-Path is bounce@thcultarfdes.co.uk. The HTML body is a pixel-perfect replica of a genuine Microsoft security alert showing a sign-in from 'Russia/Moscow, IP 103.225.77.255'. The 'Report The User' button and all hyperlinks point to mailto:sotrecognizd@gmail.com — a personal Gmail, not a Microsoft security portal. Microsoft's antispam engine assigned SCL: 5.
Sender / Target	From: no-reply@access-accsecurity.com | Return-Path: bounce@thcultarfdes.co.uk | Reply-To: sotrecognizd@gmail.com | SPF: NONE | DKIM: NONE | DMARC: PERMERROR | SCL: 5
Risk Rating	**Phishing (3/4 indicators)**
Indicators Found	CONFIRMED: Fake domain — access-accsecurity.com is not microsoft.com; SPF NONE, DKIM NONE, DMARC PERMERROR | CONFIRMED: Fear urgency — 'Unusual sign-in from Russia/Moscow — report the user immediately' | CONFIRMED: Suspicious links — 'Report The User' button opens mailto: to a personal Gmail | PARTIAL: Addressed by recipient email address (from a leaked list, not a real name)
How Attack Works	The recipient clicks 'Report The User', which opens their email client addressed to sotrecognizd@gmail.com — confirming their active email address to the attacker. A more sophisticated variant loads a Microsoft-lookalike login page harvesting credentials.
Countermeasures	Microsoft security alerts always come from @microsoft.com or @accountprotection.microsoft.com — never from access-accsecurity.com. SPF and DKIM both NONE means zero authentication. A 'Report The User' button that opens your email client (mailto:) is not how Microsoft operates.

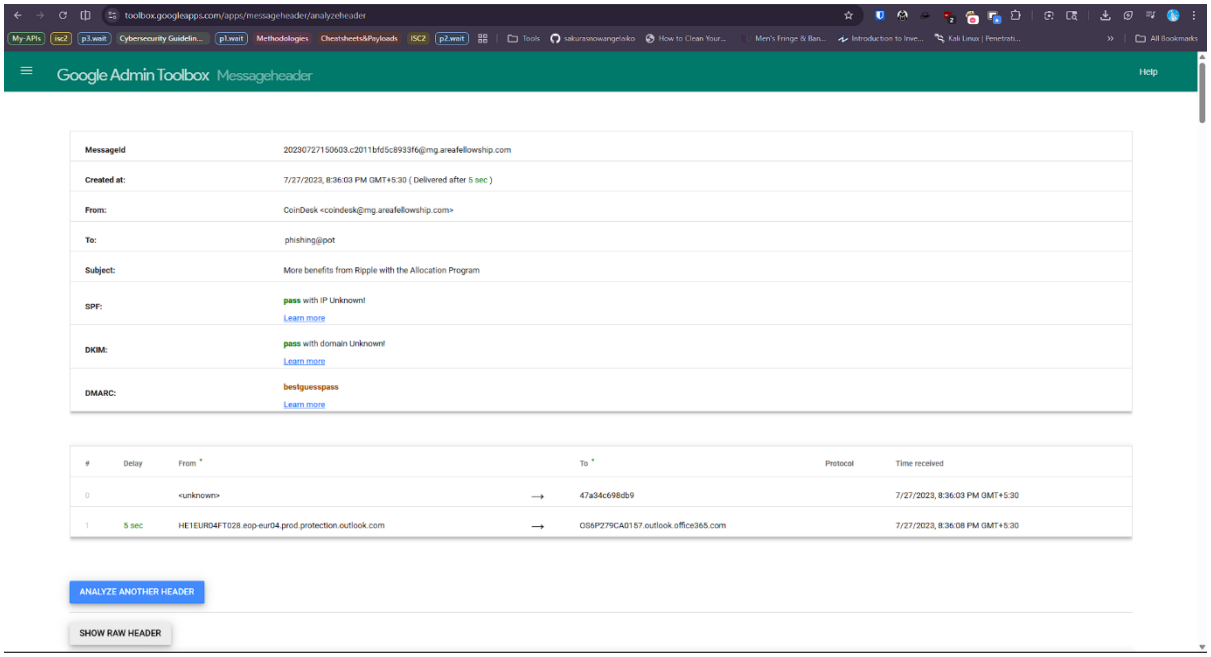
Screenshot — Google Admin Toolbox Header Analysis (E-04):



E-04

E-05 sample-1003 — Ripple/CoinDesk XRP Token Allocation Scam	
Description	Subject: 'More benefits from Ripple with the Allocation Program'. Display name 'CoinDesk' but actual sender: coindesk@mg.areafellowship.com (Mailgun subdomain of an unrelated religious organisation). All clickable links redirect to mail123-ripple.net — a fake domain designed to drain crypto wallets. The email claims a 'July 13 Court Decision' enables a Ripple Token Allocation Program with up to 30% XRP balance boosts. DMARC: 'bestguesspass' (no published DMARC policy). Microsoft assigned SCL: 9. Delivered in only 5 seconds.
Sender / Target	From: CoinDesk <coindesk@mg.areafellowship.com> | All links: mail123-ripple.net | SPF: PASS | DKIM: PASS (mg.areafellowship.com) | DMARC: bestguesspass | SCL: 9 (Junk)
Risk Rating	**Phishing (3/4 indicators)**
Indicators Found	CONFIRMED: Fake domain — CoinDesk does not send from mg.areafellowship.com | CONFIRMED: Investment FOMO urgency — 'Limited-time opportunity', '30% balance boost', 'Seize this' | CONFIRMED: Suspicious links — all hrefs go to mail123-ripple.net (not ripple.com or coindesk.com) | PARTIAL: No personal greeting — 'Welcome to The Node' newsletter impersonation
How Attack Works	The victim visits mail123-ripple.net and is shown a fake 'Token Allocation Tool' requiring connection of a cryptocurrency wallet (MetaMask, Ledger). A wallet-draining smart contract transfers all crypto assets to the attacker instantly.
Countermeasures	Real cryptocurrency giveaways are never distributed via email links. CoinDesk sends only from @coindesk.com. Never connect a crypto wallet to a page reached through an unsolicited email. DMARC 'bestguesspass' means no policy published — red flag for a major organisation.

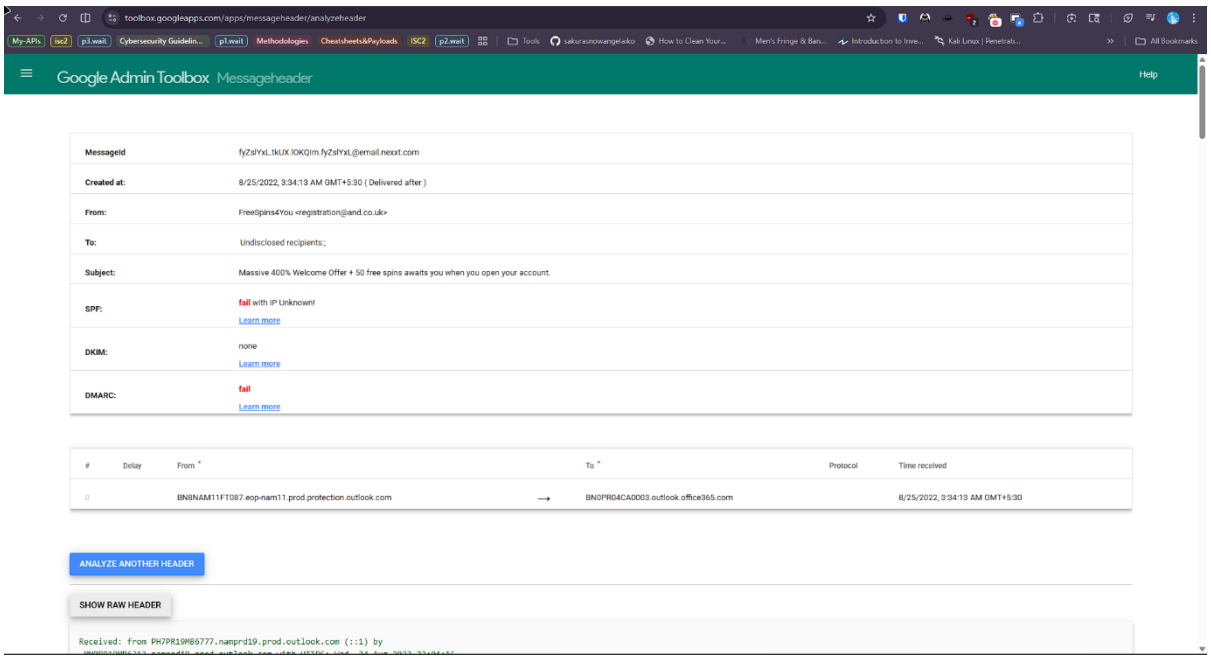
Screenshot — Google Admin Toolbox Header Analysis (E-05):



E-05

E-06 sample-14 — Gambling Spam (FreeSpins4You / and.co.uk)	
Description	Subject: 'Massive 400% Welcome Offer + 50 free spins awaits you when you open your account'. From: FreeSpins4You <registration@and.co.uk> — display name unrelated to and.co.uk (a legitimate UK business services company). SPF: FAIL. DKIM: NONE. DMARC: FAIL. To: Undisclosed recipients — clear bulk spam. The HTML body contains a single casino bonus image linking to laredouteshop.com, with a 1px tracking pixel loading from daycassino.shop. Microsoft assigned SCL: 9 (Junk).
Sender / Target	From: FreeSpins4You <registration@and.co.uk> | Return-Path: return@1643937178.tendrum.me | To: Undisclosed recipients | SPF: FAIL | DKIM: NONE | DMARC: FAIL | SCL: 9 (Junk)
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake/spoofed domain — 'FreeSpins4You' does not match and.co.uk; SPF FAIL, DMARC FAIL | CONFIRMED: Prize urgency — '400% Welcome Offer + 50 free spins — open your account' | CONFIRMED: Suspicious links — laredouteshop.com with tracking pixel on daycassino.shop | CONFIRMED: 'To: Undisclosed recipients' — pure bulk spam, no individual address
How Attack Works	The victim clicks the casino image and is redirected to an unlicensed offshore gambling site requiring registration (harvesting personal details) and an initial deposit. The daycassino.shop tracking pixel confirms the email was opened to the spammers.
Countermeasures	SPF FAIL + DKIM NONE + DMARC FAIL means the email failed every authentication check — it should have been rejected at the gateway. Licensed gambling operators always send from official verified domains and never to 'Undisclosed recipients'.

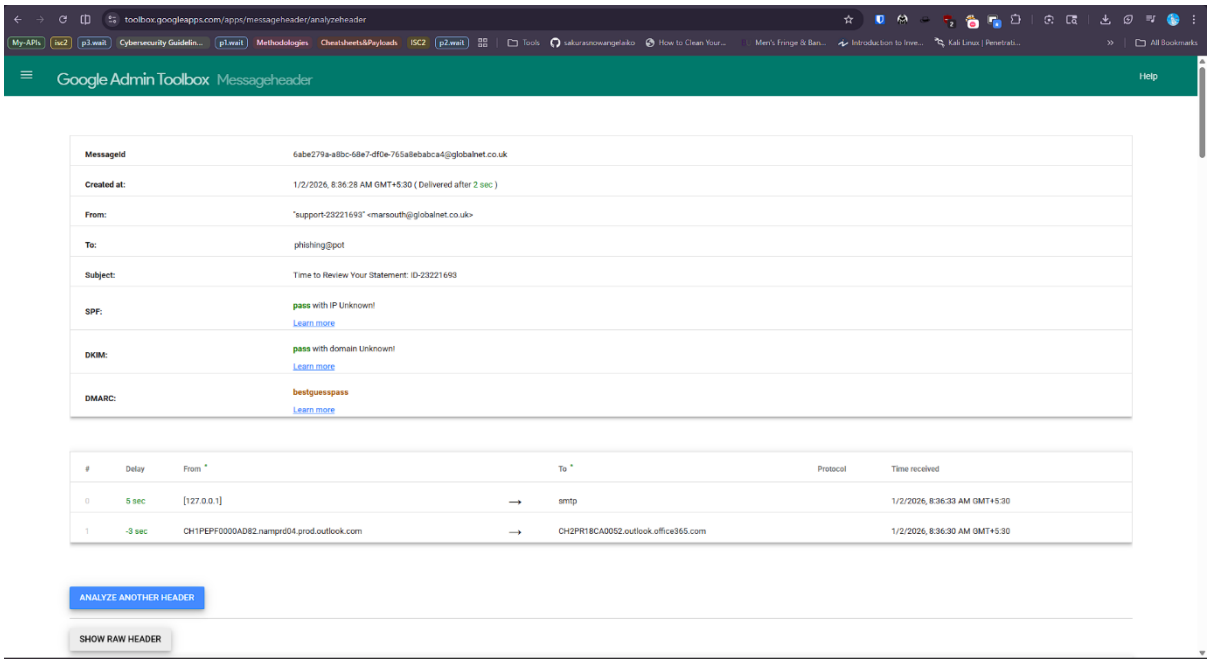
Screenshot — Google Admin Toolbox Header Analysis (E-06):



E-06

E-07 sample-7007 — Fake IRS Statement (afriink.co.za Redirect)	
Description	Subject: 'Time to Review Your Statement: ID-23221693'. From: 'support-23221693' <marsouth@globalnet.co.uk> — an alphanumeric display name with no relation to the IRS. The HTML body impersonates 'l.R.S Administration' (deliberate lowercase 'l' instead of capital 'I' to evade trademark filters). The 'View document' button links to https://afriink.dedicated.co.za/~profileplant/glen-fin-/ — a South African (.co.za) domain. DMARC: 'bestguesspass'. Originating IP [127.0.0.1] is localhost — a routing anomaly. Delivered in 2 seconds.
Sender / Target	From: support-23221693 <marsouth@globalnet.co.uk> | Link: afriink.dedicated.co.za (South Africa) | Orig IP: [127.0.0.1] | SPF: PASS | DKIM: PASS | DMARC: bestguesspass | SCL: 5
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake sender — 'l.R.S Administration' from globalnet.co.uk (a UK ISP); IRS only uses irs.gov domain | CONFIRMED: Financial fear urgency — 'confirm information is correct' implies tax consequences | CONFIRMED: Suspicious link — afriink.dedicated.co.za is South African, not irs.gov | CONFIRMED: Generic greeting — 'Dear Customer' with no taxpayer name or ID
How Attack Works	The victim clicks 'View document' and reaches the South African hosting page which presents a fake IRS login form harvesting SSN, date of birth, and banking details, or drops malware. The 'l.R.S' misspelling is a deliberate filter-bypass technique.
Countermeasures	The IRS communicates exclusively via irs.gov and postal mail — never email links. The .co.za TLD is South Africa and has no connection to the US IRS. Report IRS phishing to phishing@irs.gov. 'bestguesspass' DMARC means no policy was published.

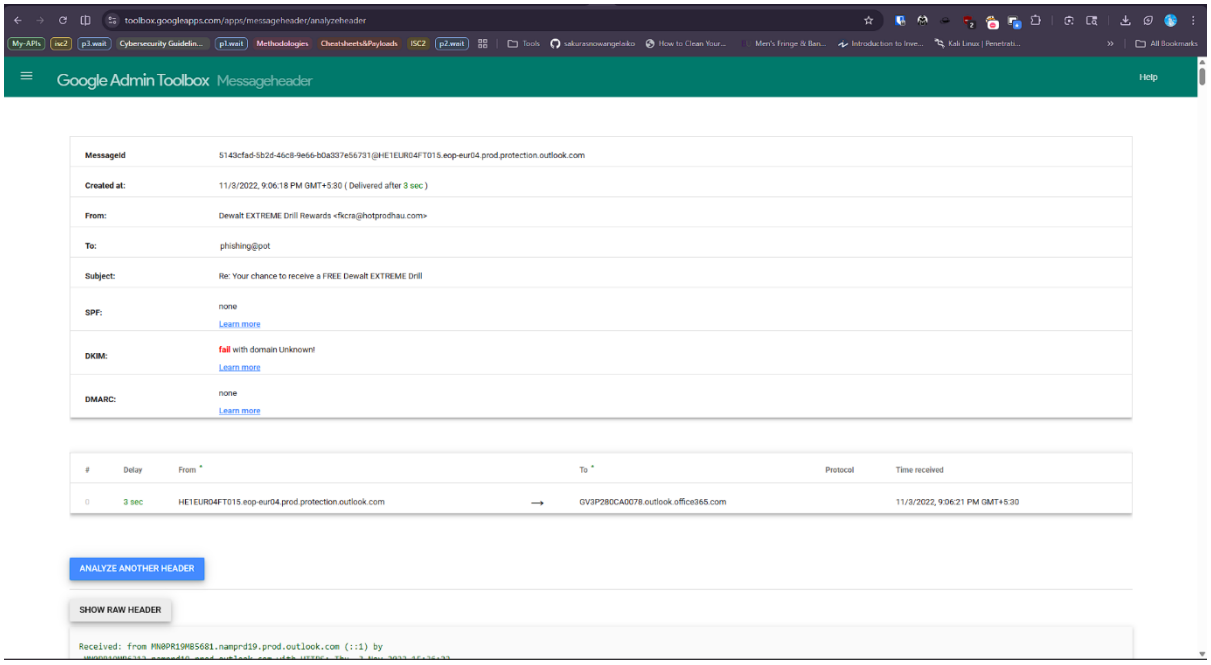
Screenshot — Google Admin Toolbox Header Analysis (E-07):



E-07

E-08 sample-104 — Fake DeWalt Drill Prize Lure	
Description	Subject: 'Re: Your chance to receive a FREE Dewalt EXTREME Drill'. From: 'Dewalt EXTREME Drill Rewards' <fkcra@hotprodhau.com>. The From domain (hotprodhau.com) has no affiliation with DeWalt (the real brand uses dewalt.com). Return-Path: indsl@gyqqo.com — a completely different domain. SPF: NONE (gyqqo.com does not designate permitted senders). DKIM: FAIL (no key found for the signature on hotprodhau.com). DMARC: NONE (no policy published). The HTML body uses two t.co shortened links pointing to unverified destinations, plus a large CSS junk block for spam-filter evasion. Delivered after 3 hours — indicating delayed bulk delivery.
Sender / Target	From: Dewalt EXTREME Drill Rewards <fkcra@hotprodhau.com> | Return-Path: indsl@gyqqo.com | Relay: adplfed.co.uk (103.167.154.112) | SPF: NONE | DKIM: FAIL | DMARC: NONE
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake domain — hotprodhau.com is not dewalt.com; Return-Path from third domain gyqqo.com | CONFIRMED: Prize urgency — 'Surprise in your inbox (for Dewalt EXTREME Drill customers Only)', 'Your chance to receive a FREE Dewalt EXTREME Drill' | CONFIRMED: Suspicious links — t.co shortened redirects pointing to unverified sites (t.co/Qi5RlxsmF5, t.co/AxwbG2YoYa) | CONFIRMED: Generic greeting — addressed to 'phishing@pot', no recipient name
How Attack Works	The victim clicks the 'FREE Dewalt Drill' link which passes through a t.co Twitter redirect to a fake prize claim page. The page requests personal details (name, address, phone) and a 'shipping and handling fee' for the free drill, harvesting payment card data. The 3-hour delivery delay and CSS junk block are spam-filter evasion techniques.
Countermeasures	DeWalt does not send prize notifications via email from hotprodhau.com or any domain other than dewalt.com. URL shorteners (t.co, bit.ly) hide the real destination — always expand shortened URLs before clicking. DKIM FAIL means the email's claimed signature could not be verified.

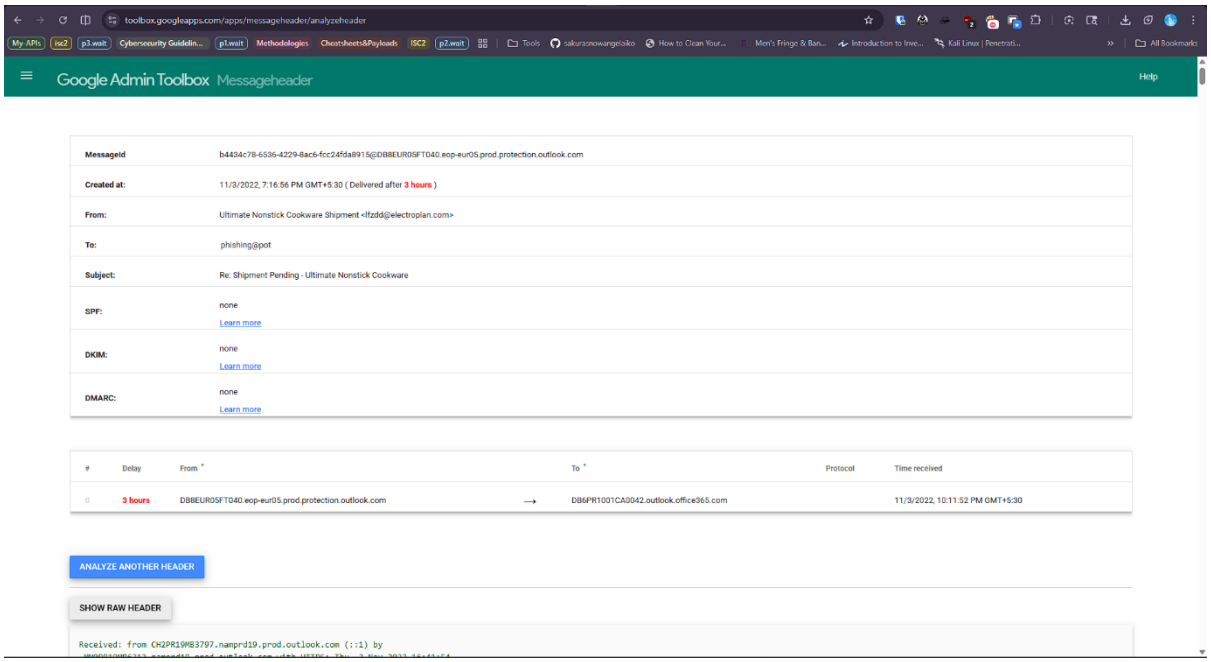
Screenshot — Google Admin Toolbox Header Analysis (E-08):



E-08

E-09 sample-106 — Fake Nonstick Cookware Sweepstakes Lure	
Description	Subject: 'Re: Shipment Pending - Ultimate Nonstick Cookware'. From: 'Ultimate Nonstick Cookware Shipment' <lfzdd@electroplan.com>. The From domain (electroplan.com) has no affiliation with any legitimate cookware brand. Return-Path: phexd@tndhp.com — a different domain entirely. SPF: NONE (tndhp.com does not designate permitted senders). DKIM: NONE (message not signed). DMARC: NONE (no policy). The HTML body announces 'CONGRATS! You are the lucky online winner of a brand new Sweepstakes Ultimate Nonstick Cookware entry!' with two t.co links. Same CSS junk block as E-08 — confirming the same spam campaign infrastructure. Delivered after 3 hours.
Sender / Target	From: Ultimate Nonstick Cookware Shipment <lfzdd@electroplan.com> | Return-Path: phexd@tndhp.com | Relay: areta.edu (89.144.11.72) | SPF: NONE | DKIM: NONE | DMARC: NONE
Risk Rating	**Phishing (4/4 indicators)**
Indicators Found	CONFIRMED: Fake domain — electroplan.com is not a cookware brand; Return-Path from unrelated domain tndhp.com | CONFIRMED: Prize urgency — 'CONGRATS! You are the lucky online winner', 'Shipment Pending' creates false expectation of an incoming delivery | CONFIRMED: Suspicious links — two t.co shortened redirects hiding real destination URLs | CONFIRMED: Generic greeting — addressed to 'phishing@pot', no recipient name
How Attack Works	Identical campaign infrastructure to E-08 (same CSS evasion block, same t.co link pattern, same 3-hour delivery delay). The victim expects a real shipment and clicks to 'confirm delivery address', landing on a credential/payment harvesting page. The 'Re:' prefix on the subject line falsely implies an ongoing conversation.
Countermeasures	Legitimate cookware companies do not send sweepstakes winnings via email from unregistered domains. The 'Re:' prefix in a subject line when you never sent that email is a social engineering tactic. Both SPF and DKIM being completely absent (NONE, not FAIL) means this email has no authentication at all — it could come from anyone.

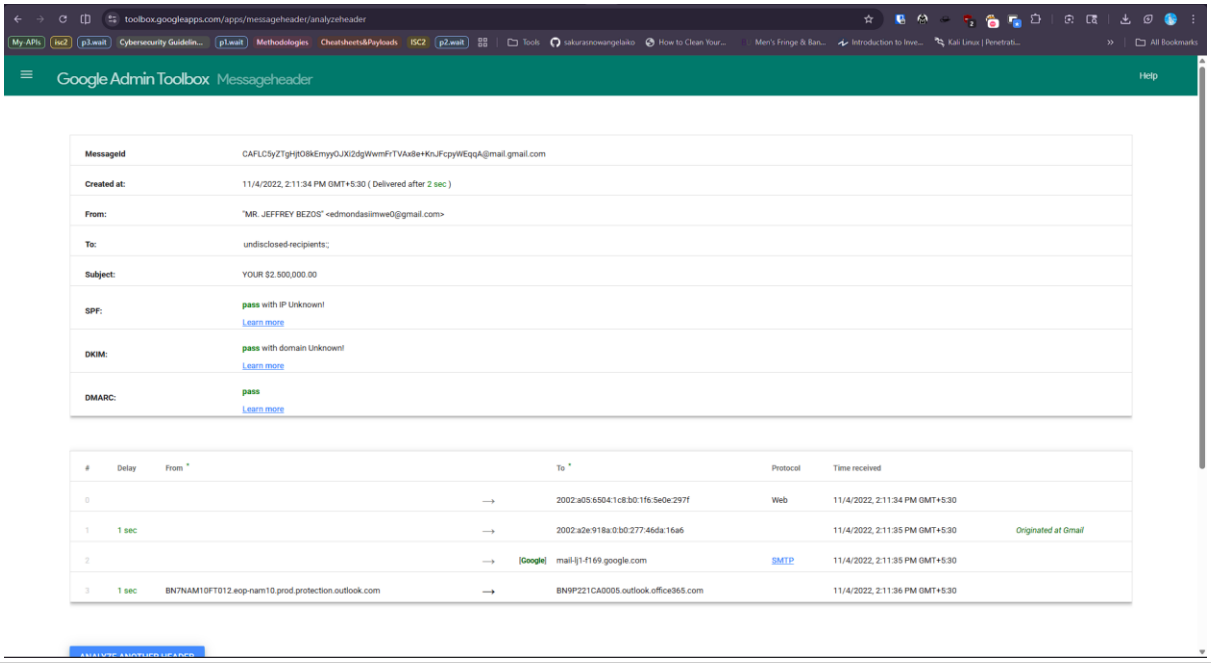
Screenshot — Google Admin Toolbox Header Analysis (E-09):



E-09

E-10 sample-107 — Jeff Bezos Impersonation Advance-Fee Fraud	
Description	Subject: 'YOUR $2,500,000.00'. From: 'MR. JEFFREY BEZOS' <edmondasiimwe0@gmail.com>. Reply-To: mrjeffreyprestonbezos07@gmail.com (a different Gmail — the real response collection address). The body is a classic advance-fee fraud (419 scam): 'Your email address has won you $2,500,000.00 — Kindly get back to me so I know your email address is valid.' To: undisclosed-recipients — bulk spam. SPF: PASS, DKIM: PASS, DMARC: PASS — all pass because it is a real Gmail account. Sent from a web browser (HTTP). Delivered after 2 seconds.
Sender / Target	From: 'MR. JEFFREY BEZOS' <edmondasiimwe0@gmail.com> | Reply-To: mrjeffreyprestonbezos07@gmail.com | To: undisclosed-recipients | SPF: PASS | DKIM: PASS (gmail.com) | DMARC: PASS | Originated at Gmail (web)
Risk Rating	**Phishing (3/4 indicators)**
Indicators Found	CONFIRMED: Fake display name — 'MR. JEFFREY BEZOS' via a random Gmail, not bezos@amazon.com | CONFIRMED: Financial lure — '$2,500,000.00 awaits you — your email address has won' | PARTIAL: No suspicious URL in body (advance-fee fraud initiates contact first before requesting personal details) | CONFIRMED: 'To: undisclosed-recipients' — bulk spam with no individual addressing
How Attack Works	This is a classic advance-fee (419) fraud. The attacker first establishes contact by getting the victim to reply (verifying the email is active). Subsequent emails request personal details, then a 'processing fee', 'tax payment', or 'bank transfer fee' to release the $2.5M — which never exists. The Reply-To address (different from the From address) captures responses even if the sender account is disabled.
Countermeasures	Jeff Bezos does not give away $2.5 million via unsolicited emails to random recipients. Any email claiming you have won a lottery or prize you never entered is a scam. The Reply-To address being different from the From address is a classic social engineering technique. Never reply to such emails — even a reply confirms your address is active, leading to more scam attempts.

Screenshot — Google Admin Toolbox Header Analysis (E-10):



E-10

7. Risk Classification Summary

ID	Sample	Fake Domain	Urgency	Bad Link	Generic Greeting	Classification
E-01	Deloitte Job Offer	Y	Y	Y	Y	**Phishing**
E-02	Payment Skipping	Y	Y	Y	Y	**Phishing**
E-03	CVS Medicare Kit	Y	Y	Y	Y	**Phishing**
E-04	MS Sign-In Alert	Y	Y	Y	P	**Phishing**
E-05	Ripple XRP Scam	Y	Y	Y	P	**Phishing**
E-06	Gambling Spam	Y	Y	Y	Y	**Phishing**
E-07	Fake IRS Statement	Y	Y	Y	Y	**Phishing**
E-08	Dewalt Drill Scam	Y	Y	Y	Y	**Phishing**
E-09	Cookware Shipment	Y	Y	Y	Y	**Phishing**
E-10	Jeff Bezos $2.5M	Y	Y	P	Y	**Phishing**

Y = Yes / Indicator confirmed | P = Partial / not fully confirmed in this sample | N = No / Not a phishing mail

8. Prevention & Awareness Guidelines

- **Check the sender's actual email address, not just the display name**
  Every sample in this report showed a convincing name — Deloitte, Medicare, Microsoft, Jeff Bezos — but the real sending address had nothing to do with that organisation. Always expand the sender field and read the full address before trusting an email.
- **Hover over links before clicking anything**
  Several emails in this analysis hid their real destinations behind Azure Blob URLs, a South African .co.za domain, or t.co short links. A quick hover reveals where a link actually goes. If the destination looks nothing like the organisation's official website, don't click.
- **Failing authentication is a red flag — but passing isn't a green light either**
  E-04, E-06, E-08, and E-09 all failed SPF, DKIM, or DMARC checks — a clear warning sign. But E-01, E-02, E-03, and E-10 passed every check and were still phishing. Authentication confirms who sent the email, not whether they're trustworthy. When in doubt, paste the headers into Google Admin Toolbox.
- **Look up the sending IP on Cisco Talos**
  For the real received emails, a quick Talos lookup told the full story — E-01's IP traced to a small Indian ISP with no connection to Deloitte, and E-02/E-03 came through Gmail because the attacker just used a real Gmail account.
- **If you didn't enter it, you didn't win it**
  Six of the ten samples used some kind of prize or reward to get a click — free drills, cookware, crypto bonuses, a $2.5M lottery. Legitimate companies don't send unsolicited winnings by email. Treat any unexpected reward as a warning sign, not an opportunity.
- **A "Re:" in the subject line means nothing**
  E-09 arrived as "Re: Shipment Pending" despite no prior conversation existing. Attackers add "Re:" to make an email feel familiar. If you don't remember the conversation it's referencing, you didn't have one.
- **Turn on MFA, and report before you delete**
  If a phishing page does grab your password, MFA stops the attacker from actually getting in. And before hitting delete on a suspicious email, report it — your colleagues are likely receiving the same campaign, and your report can stop it spreading.

9. Do's and Don'ts for Employees

DO	DON'T
Hover over links to check the actual destination URL before clicking	Click any link in an unsolicited email without first verifying the destination
Check the full sender email address — not just the display name	Trust an email because the display name shows a known brand (DELOITTE, IRS, Microsoft, DeWalt, Jeff Bezos)
Use Google Admin Toolbox + Talos Intelligence to analyse suspicious headers	Assume SPF/DKIM/DMARC passing means the email is legitimate — check the actual domain
Navigate directly to official websites (type URL manually) for urgent messages	Use links in emails to access banking, payment, account, or government pages
Report suspected phishing to your IT security team before deleting	Delete suspicious emails without reporting — colleagues may receive the same campaign
Enable MFA on all critical accounts (email, cloud, banking, social media)	Rely solely on passwords — MFA blocks attackers even if they steal your password
Verify unexpected prize, job, lottery, or payment emails via official channels	Provide personal or payment details on any page reached through an unsolicited email link
Download attachments only from verified, expected senders	Download files to 'receive a free prize' or 'claim lottery winnings' from unsolicited email
Be alert if DMARC shows 'bestguesspass' or 'none' — the domain has no protection	Assume emails passing SPF/DKIM are safe — E-01/E-02/E-03/E-10 all passed yet were phishing emails.